

Oversight of Notification of Breach of Personal Data Security

Date: 31-08-2023

Decision

Private Companies

No Criticism

Supervision / Self-initiated Case

Notification of Breach of Personal Data Security

The Data Protection Agency has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of personal data security. The Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-41-0132.

Sydbank A/S (hereinafter Sydbank) was among the companies that the Data Protection Agency selected for oversight in the autumn of 2021 under the General Data Protection Regulation[1] and the Data Protection Act[2].

The Data Protection Agency's oversight was a written inspection, which among other things focused on whether Sydbank had implemented appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, with the aim of reducing the number of breaches of personal data security, where there was unauthorized disclosure of personal data, including confidential information, particularly in relation to financial information.

The oversight was announced to Sydbank by letter dated November 24, 2021, and the bank was simultaneously requested to respond to a series of questions and to submit an example of an instruction to the bank's employees regarding the handling of personal data, including in connection with the transmission of information to, among others, citizens, authorities, etc.

The Data Protection Agency informed about the background for the oversight, stating that a review of the Agency's cases concerning notifications of breaches of personal data security revealed that Sydbank had reported significantly more breaches of personal data security per employee in the financial institution than other financial institutions. The Data Protection Agency noted in this context that the higher number of notifications does not necessarily indicate that the bank complies with data protection regulations to a lesser extent than financial institutions that have significantly fewer notifications per employee.

By letter dated January 19, 2022, Sydbank sent a statement in which the bank responded to the Data Protection Agency's questions. Sydbank's response was also accompanied by examples of relevant instructions and guidelines.

Summary

In the summer and autumn of 2021, the Data Protection Agency initiated written inspections of the handling of breaches of personal data security by eight larger municipalities and eight larger banks. The inspections were organized such that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipality's population and the number of employees in the bank, respectively.

"One of the new things that came with GDPR over five years ago was that data controllers, as a general rule, must report all breaches of personal data security to the Data Protection Agency within 72 hours, and they must also internally document all breaches of personal data security, regardless of whether they need to be reported to the Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, chief consultant at the Data Protection Agency, and continues: "This may, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some random samples. The conclusion is broadly that the 16 selected municipalities and banks seem to have the right focus on complying with the rules."

Group with the Most Reported Breaches

For the group with the most reported breaches, the inspections focused, among other things, on

whether the municipalities and banks had implemented appropriate security measures to reduce the number of breaches of personal data security, where there was unauthorized disclosure of personal data in connection with the transmission of information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons. The data controller must, in this context, ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Agency found, on the basis of the information available, that all data controllers had implemented appropriate security measures. In its assessment, the Data Protection Agency emphasized that:

Procedures, etc. had been developed and activities had been carried out to educate employees in data protection, including to ensure that they are aware that there is no accidental disclosure of personal data to an incorrect recipient.

They have made considerations and continuously implemented both technical and organizational measures in response to past breaches of personal data security to avoid similar breaches. There is a strong focus on preventing unintended disclosure of confidential information, which is supported by business processes, ongoing guidance, etc., and systemic initiatives, etc.

****The Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the data protection regulation, including their processes for handling and recording breaches of personal data security. The Data Protection Authority stated in these cases that it is the Authority's opinion that compliance with the rules stating that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours entails that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this context, the data controller must ensure that all employees in the organization are familiar with internal procedures for handling breaches of personal data security to the necessary extent, and that relevant employees can identify, handle, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have conducted appropriate training activities that can support compliance with the requirements in the data protection regulation regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including, among other things, the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that it had not had the opportunity as part of the inspection to concretely assess whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives. Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with. Therefore, data controllers should document their reasons for all significant decisions made as a result of the breach. This applies not least if the data controller, after assessing the breach, concludes that it does not need

to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****Criticism in Two Cases****

As mentioned, there is pronounced criticism in two of the cases – specifically concerning two municipalities that did not document all breaches of personal data security. In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified in the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the registered security incidents since September 2019 constitute actual breaches of personal data security. In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality has identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to, among other things, gain an overview of what types of breaches typically occur in the organization, and based on this, consider whether there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It is also indicated in the received consultation responses that several of the data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds on the basis of the present information that Sydbank has taken appropriate security measures in accordance with Article 32, paragraph 1, of the data protection regulation, with the aim of reducing the number of breaches of personal data security involving unauthorized disclosure of personal data, including confidential information, particularly in relation to financial information. Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

It is stated in Article 32, paragraph 1, of the data protection regulation that the data controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing activities.

the Data Protection Authority. Thus, the data controller has an obligation to identify the risks that its processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks. The Data Protection Authority believes that the requirement in Article 32 for appropriate security will generally entail that the data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons, and that the data controller must ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc., and that procedures, guidelines, workflows, technical security measures, etc., are continuously updated or introduced, including as a result of identified breaches of personal data security.

Sydbank stated in its statement of January 19, 2022, that the bank, in connection with the application of the General Data Protection Regulation (GDPR) from May 2018, developed a number of business processes, job descriptions, and guidelines, including for how personal data should be handled, how they may be transported, and how a data breach should be managed. Sydbank indicated that the most important documents have been submitted along with the statement, and they have also been reviewed in the statement. The following business processes/guidelines, etc. have been submitted (Appendix 1 contains an overview): Business process for secure communication (Appendix 2), Choice of channel – decision tree (Appendix 3), Business process for what you may note (Appendix 4), Business process for storage and deletion of files on drives (Appendix 5), Business process for breaches of personal data security (Appendix 6), Job description for handling data breaches (Job description for handling data breaches (Appendix 7), Business process for classification of personal

data and appendices thereto (Appendices 8 and 9), IT's use of the business process for classification of personal data (Appendix 10), E-learning: Awareness of data breaches (Appendix 11), Excerpt from e-learning material: Processing of personal data in Sydbank (Appendix 12), and Pop-up message and warning and recipients outside the organization (Appendix 13).

Sydbank initially stated that the bank began to work purposefully with the General Data Protection Regulation in the organization prior to May 2018, and that there has since been a strong focus on data breaches. A department has been established where the operation of GDPR is anchored, and which handles all of the bank's data breaches. In this context, a control has been established to ensure that all breaches are correctly risk assessed.

In 2021, Sydbank adjusted its reporting procedure regarding data breaches, which has resulted in several notifications to the Data Protection Authority. This is due to a changed risk assessment of when a data breach should be reported. In this context, it has been assessed that a data breach that results in a breach of confidentiality under the Financial Business Act should, in principle, be reported to the Data Protection Authority. This also includes breaches that concern a few non-sensitive personal data, including, for example, an unintended disclosure of information that a person (identified by first and last name) is a customer of the bank. However, Sydbank will continue to make a holistic assessment based on the scope, context, and purpose of the breach.

Sydbank has stated that the business process for secure communication describes how communication is handled securely in the bank, and that the focus is on what should be done when communicating externally. It is based on a risk-based approach that ensures that the higher the risk, the better the security must be around the transmission.

The business process for what may be noted helps advisors to record information about customers in the most appropriate way, and there is a monthly control with random samples to ensure that the guidelines are followed. The business process for storage and deletion on drives aims to ensure that information is stored in the right place and thus also minimizes the risk of data breaches. The business process for handling breaches describes what a data breach is, as well as the procedure for informing the GDPR department. There is also a job description that aims to ensure a consistent handling of breaches in the GDPR department.

In connection with considerations about the risk of unintended disclosure of information, including confidential information, Sydbank has stated that as a financial institution, it is subject to confidentiality under the Financial Business Act, and therefore it is part of its foundation to work with confidentiality. Handling confidential information is an ingrained part of the work for the bank's employees, and the work with confidentiality is therefore also incorporated into the GDPR work. This is done, among other things, by working with data classification, which aims to clarify for employees the risks and consequences associated with different categories of information. Data classification is also used by the IT department to know whether a given personal data requires special focus, including regarding security measures. Data classification is also incorporated into the business processes that instruct employees on how to choose the correct communication channel in relation to the information that is sent out of the bank, as it requires more diligence and security the higher the classification of the information.

Sydbank further stated that since 2018, several measures have been implemented focusing on preventing breaches of personal data security, and this should be seen in conjunction with the fact that the bank has continuously informed employees that all breaches must be reported to the Data Protection Authority.

GDPR Department. Breaches are logged here, and statistics are generated regarding these breaches, which are used to analyze the breaches with a view to implementing various measures of both technical and organizational nature, where deemed necessary.

As examples of organizational measures, Sydbank has stated that awareness campaigns were conducted in the months around May 2018, including a site about personal data and news on the bank's intranet. Furthermore, a day was allocated for GDPR training at the annual leadership

conference in March 2018, and subsequently, all employees were trained through e-learning, where they were also instructed on how to identify and handle a breach.

It is part of Sydbank's annual cycle that training in data protection is conducted, including a focus on data breaches. E-learning has been carried out for the entire organization in 2018, 2019, 2020, and in 2021. As a supplement to e-learning, the GDPR department, in collaboration with the DPO, has visited all of the bank's decentralized areas multiple times for GDPR training. All areas' data breaches were included, allowing for concrete discussions in the respective areas. In several cases, statistics have shown that there have been specific types of breaches in certain departments, and the GDPR department has therefore had a particular focus on such situations. This has, for example, led to a dedicated effort in certain areas, resulting in a significant reduction in the number of breaches in those areas.

In addition to the aforementioned organizational measures, Sydbank has also reported a number of technical measures aimed at reducing the number of breaches resulting from unintentional disclosures and the associated risks, such as automatic deletion of old emails, pop-up notifications when an email with attachments is sent to external email addresses, and by replacing the last four digits of customers' personal identification numbers with XXXX in the bank's documents.

Regarding considerations for further organizational and technical measures, Sydbank has stated that the GDPR department will continue to prepare analyses of data breaches that have occurred, so that both general and specific measures can be implemented concerning individual areas or departments. The bank has already planned several awareness initiatives for 2022, as well as considerations for the removal of automatic filling of email addresses and the introduction of a Data Loss Prevention solution to screen emails and attachments for certain information, including personal identification numbers.

It is – despite the fact that the Data Protection Authority has not had the opportunity to take a concrete position on whether all relevant employees have completed the relevant training activities, and that the authority is not familiar with the full content of all guidance and training materials – based on the information available, the authority's assessment is that Sydbank has overall taken appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, with a view to reducing the number of breaches of personal data security, where there is unauthorized disclosure of personal data, including confidential information, particularly in relation to financial information.

In its assessment, the Data Protection Authority has emphasized the information provided by Sydbank, including that procedures, etc., have been developed and activities have been conducted to educate employees in data protection, including to ensure that they are aware that there is no unintentional disclosure of personal data to an incorrect recipient, that Sydbank has considered and continuously implemented both technical and organizational measures following past breaches of personal data security to avoid similar breaches, and that there is a strong focus on avoiding unintentional disclosure of confidential information, which is supported by business processes, ongoing guidance, etc., and systematic measures that aim to create secure communication channels between the bank's employees and customers.

The Data Protection Authority can, upon a renewed review of the authority's cases regarding reports of breaches of personal data security, ascertain that since November 24, 2021, there has not been a decrease in the number of reported breaches of personal data security from Sydbank. However, the Data Protection Authority has noted that Sydbank adjusted its reporting procedure regarding data breaches in 2021, which has resulted in more reports to the Data Protection Authority. As there continues to be a number of reports of breaches of personal data security where there has been unauthorized disclosure of personal data, the Data Protection Authority recommends that the bank continues to focus on conducting training and awareness activities, etc., and ensuring that procedures, guidelines, workflows, technical security measures, etc., are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Authority finally notes that the authority – typically if the authority receives new

reports of breaches of personal data security – may resume the processing of previously reported breaches or include them in the assessment of any future breach or complaint cases.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons with regard to the processing of personal data and on the free movement of such data. (Data Protection Act)